

Narrativa Explicativa

Por qué una Encuesta sobre la Pirámide del Dolor

La vida moderna en ciberseguridad está llena de dashboards. Tanto, que a veces olvidamos preguntarnos si medimos aquello que realmente importa. Contamos incidentes, tickets, parches aplicados, horas de formación, pero rara vez miramos de frente la pregunta incómoda: ¿cuánto le duele al adversario lo que hacemos?

La Pirámide del Dolor, propuesta por David Bianco, se ha convertido en un clásico de las presentaciones de threat hunting. En su forma más sencilla, ordena los indicadores de compromiso desde lo más fácil de cambiar para el atacante (hashes, IPs, dominios) hasta lo más costoso (herramientas y TTP, tácticas, técnicas y procedimientos). Es un recordatorio visual de que no todas las detecciones son iguales, ni todos los indicadores infligen el mismo grado de incomodidad a quien está al otro lado.

Sin embargo, en demasiadas organizaciones la Pirámide vive en las diapositivas, no en las métricas. Se invierten recursos considerables en recolectar y procesar IoC de bajo nivel, mientras la cúspide —la detección basada en comportamiento adversario— se queda infraalimentada. Esta encuesta nace precisamente para arrojar luz sobre esa asimetría.

Un espejo, no un examen

El diseño de las preguntas busca algo más que una foto de tecnologías desplegadas. Intenta capturar:

- Cómo se organiza la detección a lo largo de los niveles de la Pirámide.
- Qué métricas se utilizan para evaluar su eficacia.
- Cómo se reporta y gobierna todo ello.
- Y, en última instancia, qué grado de “dolor” podemos afirmar, con cierta seriedad, que causamos al adversario.

El tono ligeramente irónico que asoma en algunas opciones de respuesta no es gratuito. Es una invitación a la autoironía profesional: todos hemos vivido proyectos donde se medía con exquisito detalle aquello que era fácil de contar, mientras se ignoraban variables mucho más determinantes para la seguridad real.

La encuesta no pretende ser un examen normativo ni otorgar certificados de virtud cibernética. Es un espejo relativamente sofisticado. Si uno prefiere maquillarse antes de mirarse, es libre de hacerlo, pero el valor del ejercicio disminuirá proporcionalmente.

De los hashes a los hábitos del adversario

En los primeros bloques, la encuesta se detiene en los indicadores de bajo nivel: hashes, IPs, dominios. No para demonizarlos, sino para situarlos en su justo lugar. Son útiles, sí, pero cada vez más efímeros. El cuestionario indaga si la organización:

- Mide el tiempo de vida de estos indicadores.
- Gestiona su caducidad o acumula listas infinitas.
- Los enriquece con contexto o los consume como materia prima barata.

A continuación, el foco se desplaza a los artefactos de red y host: patrones de tráfico, trazas en EDR/XDR, combinaciones de eventos. Aquí es donde la detección empieza a adquirir profundidad. Las preguntas apuntan a si se mide la capacidad de estas reglas para anticiparse a incidentes graves, y si se revisan periódicamente para reducir ruido y aumentar precisión.

Finalmente, la encuesta asciende a la cumbre: herramientas y TTP. Se explora el grado de uso de MITRE ATT&CK, la existencia (o ausencia) de métricas de cobertura, la práctica de mapear detecciones a técnicas observadas y la capacidad de elevar reglas triviales a detecciones basadas en comportamiento. Si en algún momento el lector siente que el vértigo aumenta a medida que sube, la metáfora funciona.

El dolor, cuantificado (hasta donde se pueda)

Hablar de “dolor infligido” al adversario no es una licencia poética; es una manera de replantear métricas clásicas. Tiempo medio de detección y respuesta, número de incidentes, falsos positivos: todo eso sigue importando. Pero la encuesta empuja a distinguir:

- Qué incidentes fueron detectados por indicadores superficiales.
- Cuáles se interceptaron gracias a detecciones profundas.
- Qué diferencia práctica supuso una cosa u otra.

No siempre será posible cuantificarlo con precisión; la vida real es más desordenada que los papers académicos. Pero incluso una aproximación cualitativa (por ejemplo, a través de preguntas sobre reducción de ataques exitosos atribuible a TTP) ayuda a desplazar la conversación.

Gobernanza y narrativa: del SOC al Consejo

Ninguna métrica vive aislada. Las preguntas sobre gobernanza y normativa intentan captar hasta qué punto esta visión piramidal:

- Se refleja en las políticas internas.
- Se traduce en reportes a la alta dirección.
- Se encaja con marcos regulatorios como NIS2, ENS, RGPD o estándares ISO.

Un SOC puede hacer maravillas con sus reglas, pero si al Consejo sólo le llegan gráficos de “incidentes bloqueados” sin matiz, la Pirámide se aplanará inevitablemente en el PowerPoint. La encuesta invita a preguntarse qué relato se está construyendo hacia arriba: ¿uno basado en cantidad de alertas, o en calidad de la presión ejercida sobre los adversarios?

Una herramienta para la conversación

Más allá de los números, esta encuesta está pensada como catalizador de conversaciones incómodas pero necesarias:

- Entre ciberseguridad y TI (¿qué telemetría hace falta para detectar TTP?).
- Entre ciberseguridad y negocio (¿qué impacto tienen los incidentes que sí se cuelfan?).
- Entre organizaciones de un mismo sector (¿cómo compartir algo más que IoC triviales?).
- Entre países y reguladores (¿qué indicadores deben pedirse para fomentar detección de alto nivel?).

En un mundo donde proliferan los marcos, las normas y los sellos, la Pirámide del Dolor aporta una sencillez peligrosa: nos obliga a reconocer que no todos los esfuerzos valen lo mismo. La encuesta pretende traducir esa intuición en un conjunto de preguntas concretas, que puedan responderse sin necesidad de haber leído los últimos informes académicos, pero con la vista puesta en las tendencias más recientes.

Epílogo: cómo leer las respuestas sin caer en el cinismo

Es posible que, tras analizar varias organizaciones, la conclusión sea desalentadora: demasiadas ancladas en la base de la Pirámide, pocas jugando en serio en la cúspide. Es tentador entonces caer en el cinismo: “esto nunca va a cambiar”. La intención de esta herramienta es precisamente la contraria.

Ver claramente dónde estamos es el primer paso para trazar un camino plausible hacia donde queremos ir. Cada respuesta honesta, incluso (o sobre todo) las que confiesen carencias, es un ladrillo en esa dirección. Si el resultado final de la encuesta es que algunos responsables se sientan incómodos al ver cuánto esfuerzo dedican a perseguir hashes que caducan en horas, tal vez esa incomodidad sea el indicador de madurez más valioso de todos.

Porque al final, la Pirámide del Dolor no habla tanto del sufrimiento del adversario como de nuestra disposición a asumir el propio: el esfuerzo de diseñar detecciones más inteligentes, de medir lo que importa, de explicar mejor por qué ciertas inversiones son innegociables. Si esta encuesta sirve de excusa para empezar ese diálogo, habrá cumplido su propósito.